

Manual 26 — Implementação Controlada de Resposta a Incidentes e Gestão de Crises Cibernéticas

Tradução de projeto pt-BR — não oficial.

Base de fontes: NIST SP 800-61 Rev. 3 (final, abril de 2025) substitui a Rev. 2 e alinha a resposta a incidentes ao CSF 2.0. As orientações da CISA e as regras de notificação específicas por jurisdição são fontes de apoio ou sobreposição e não devem ser tratadas como universalmente vinculantes. Revalide o estado atual das fontes antes da publicação.

01. Propósito, escopo e limite de assurance

Defina um modelo prático de operação para resposta a incidentes e crises cibernéticas sem implicar suficiência jurídica universal, reportabilidade de violações ou opinião de auditoria.

02. Hierarquia de fontes e controle de versões

Separe orientações do NIST, orientações da CISA, regras regulatórias de notificação, obrigações contratuais, sobreposições setoriais, requisitos de seguradoras e política interna.

03. Governança e responsabilização executiva

Atribua patrocinador executivo, comandante do incidente, líder de crise, funções jurídicas e de privacidade, autoridade de comunicações, responsáveis de negócio e responsabilização por evidências.

04. Política de resposta a incidentes

Defina escopo, autoridade, limiares de severidade, escalonamento, evidências, comunicações, recuperação, lições aprendidas e requisitos de governança.

05. Preparação organizacional

Mantenha prontidão de pessoas, processos, ferramentas, registros, dados de contato, acessos, backups, capacidade forense, fornecedores e suporte à decisão.

06. Contexto de ativos, serviços e dependências

Vincule a resposta a incidentes a serviços críticos, ativos, identidades, aplicações, serviços em nuvem, fornecedores, instalações e processos de negócio.

07. Planejamento de ameaças e cenários

Mantenha bibliotecas de cenários para ransomware, roubo de dados, comprometimento de contas, abuso de nuvem, eventos de cadeia de suprimentos, malware destrutivo, uso indevido interno e interrupção de serviços.

08. Detecção e entrada de eventos

Defina fontes monitoradas, triagem de alertas, reporte por usuários/fornecedores, canais de escalonamento, dados mínimos de entrada e preservação de evidências.

09. Triagem e análise inicial

Avalie credibilidade, escopo, serviços afetados, indicadores, impacto provável, incerteza e necessidades imediatas de contenção.

10. Declaração e severidade do incidente

Use critérios documentados de declaração e níveis de severidade vinculados a impacto, propagação, gatilhos jurídicos/regulatórios, dano a clientes, segurança e atenção executiva.

11. Estrutura de comando do incidente

Defina comando operacional, frentes especializados, autoridade decisória, transições, ritmo operacional e requisitos do registro de comando.

12. Integração com gestão de crises

Escale do tratamento de incidentes para governança de crise empresarial quando forem atingidos limiares de negócio, jurídicos, de segurança, reputacionais, geopolíticos ou executivos.

13. Investigação e preservação de evidências

Preserve logs, imagens, artefatos, cronologias, registros de cadeia de custódia, notas de analistas e evidências de decisão proporcionais às necessidades jurídicas e operacionais.

14. Estratégia de contenção

Selecione ações de contenção de curto e longo prazo com base em impacto, persistência do invasor, criticidade do negócio, segurança, dano a clientes e restrições de recuperação.

15. Erradicação e análise de causa raiz

Remova presença maliciosa, corrija fragilidades exploradas, invalide credenciais comprometidas, elimine persistência e documente fatores causais.

16. Planejamento de recuperação

Defina ordem de restauração, critérios de estado limpo, validação de segurança, aceitação pelo responsável de negócio, monitoramento, rollback e decisões de risco residual.

17. Recuperação de identidade e acesso

Trate redefinição de credenciais, revogação de tokens, acesso privilegiado, controles de emergência, federação, contas de serviço e comprometimento do provedor de identidade.

18. Resposta a ransomware e extorsão

Defina governança decisória para criptografia, roubo de dados, extorsão, autoridades policiais, seguradora, jurídico, comunicações, restauração e revisão relacionada a sanções, sem prescrever decisões de pagamento.

19. Coordenação de violação de dados e incidentes de privacidade

Coordene privacidade, jurídico, segurança, registros, clientes, reguladores e avaliação específica por jurisdição, preservando testes distintos de reportabilidade.

20. Notificação regulatória e contratual

Mantenha uma matriz de notificação consciente de jurisdições e obrigações com campos de gatilho, prazo, autoridade, responsável, conteúdo, evidência e controle de mudanças.

21. Incidentes de terceiros e cadeia de suprimentos

Defina notificação de fornecedores, evidência, coordenação de contenção, serviço alternativo, escalonamento contratual, assurance e resposta a risco de concentração.

22. Incidentes em nuvem e SaaS

Trate responsabilidade compartilhada, logs do provedor, isolamento do tenant, identidade, abuso de API, impactos regionais, acesso a evidências, escalonamento ao provedor e dependências de recuperação.

23. Incidentes OT/ICS e sensíveis à segurança

Preserve segurança, confiabilidade, autoridade de engenharia, restrições do processo, evidências, coordenação com fornecedores e escalonamento setorial acima de ações puramente centradas em TI.

24. Comunicações e gestão de partes interessadas

Defina comunicações internas, avisos a clientes, resposta à mídia, autoridade do porta-voz, aprovação de mensagens, controle de rumores e briefings executivos.

25. Registro de decisões e registros de crise

Mantenha decisões com carimbo de tempo, premissas, evidências consideradas, aprovadores, alternativas, riscos residuais e ações de acompanhamento.

26. Privilégio jurídico e limites de investigação

Coordene decisões lideradas por assessoria jurídica quando apropriado sem presumir que o privilégio se aplique automaticamente; separe fatos operacionais de conclusões jurídicas.

27. Integração com continuidade de negócios e recuperação de desastres

Vincule a resposta a incidentes à ativação do SGCN, recuperação de desastres, operações alternativas, continuidade de fornecedores e limiares de gestão de crises.

28. Exercícios e simulações

Execute exercícios de mesa, técnicos, executivos, com fornecedores, ransomware, nuvem, comunicações e crises integradas com objetivos mensuráveis.

29. Métricas e gestão de desempenho

Acompanhe detecção, declaração, contenção, erradicação, recuperação, recorrência, achados de exercícios, prontidão para notificação, envelhecimento de problemas e completude das evidências.

30. Revisão pós-incidente e remediação

Realize lições aprendidas, validação de causa raiz, análise de lacunas de controle, acompanhamento de ações, aceitação de risco residual e verificação de encerramento.

31. Assurance e análise crítica pela direção

Forneça revisão independente e supervisão da liderança sobre prontidão, incidentes, exercícios, métricas, achados, recursos e prioridades de melhoria.

32. Publicação, evidência e roteiro de implementação

Empacote caminhos de implementação Essencial / Estruturado / Aprimorado com verificação de fontes, localização, acessibilidade, proveniência, checksums, segurança de workflows, identidade exata do candidato e controles de publicação sequencial.